

Lab7:IoT & Enterprise Network Forensic Investigation Using Wireshark

Lab Overview

In this lab, I conducted a network forensic investigation involving BookWorld, a simulated major online bookstore. The investigation focused on unusual activity observed in the BookWorld database environment, including increased query volumes and elevated server resource usage that indicated possible malicious activity.

As part of the investigation, I analyzed the available network traffic to examine the nature of the suspicious activity, identify the apparent method of compromise, assess the potential scope of the incident, and document the findings in a forensic investigation report.

The investigation built upon the packet analysis, filtering, and traffic-pivoting techniques developed in **Lab 6**, which were applied to investigate and interpret the network traffic in this scenario.

Exercise 1:

The overall traffic behavior.

Protocol	Percent Packets	Packets	Percent Bytes	Bytes	Bits/s	End Packets	End Bytes	End Bits/s	PDI
Frame	100.0	88862	100.0	28629039	80 k	0	0	0	888
Ethernet	100.0	88862	4.3	1244068	3,514	0	0	0	888
Internet Protocol Version 4	100.0	88862	6.2	1777240	5,020	0	0	0	888
User Datagram Protocol	0.1	122	0.0	976	2	0	0	0	122
Data	0.1	122	0.0	5368	15	122	5368	15	122
Transmission Control Protocol	99.9	88740	9.9	2847104	8,042	5313	178148	503	887
Hypertext Transfer Protocol	93.9	83418	38.8	11096504	31 k	41759	4368214	12 k	834
Portable Network Graphics	0.0	3	0.0	4071	11	3	4071	11	3
MIME Multipart Media Encapsulation	0.0	1	0.0	441	1	1	441	1	1
Line-based text data	46.9	41645	40.7	11664808	32 k	41645	11664808	32 k	416
HTML Form URL Encoded	0.0	4	0.0	129	0	4	129	0	4
Compuserve GIF	0.0	6	0.0	1218	3	6	1218	3	6
Data	0.0	9	0.0	9	0	9	9	0	9

The captured traffic is heavily web-based, with HTTP accounting for the majority of observed packets. Most communication occurs over TCP, indicating sustained client-server interactions.

Do you observe repeated connections or unusual communication patterns?

Yes. The extremely high volume of HTTP traffic over 83,418 packets suggests repeated interactions with the web application.

What early indicators suggest malicious activity?

1. Excessive HTTP traffic volume.
2. Large number of repeated web requests.
3. Significant amount of line-based text data transferred through HTTP.
4. Traffic concentration around web services.

Step 2: Identifying Suspicious Hosts

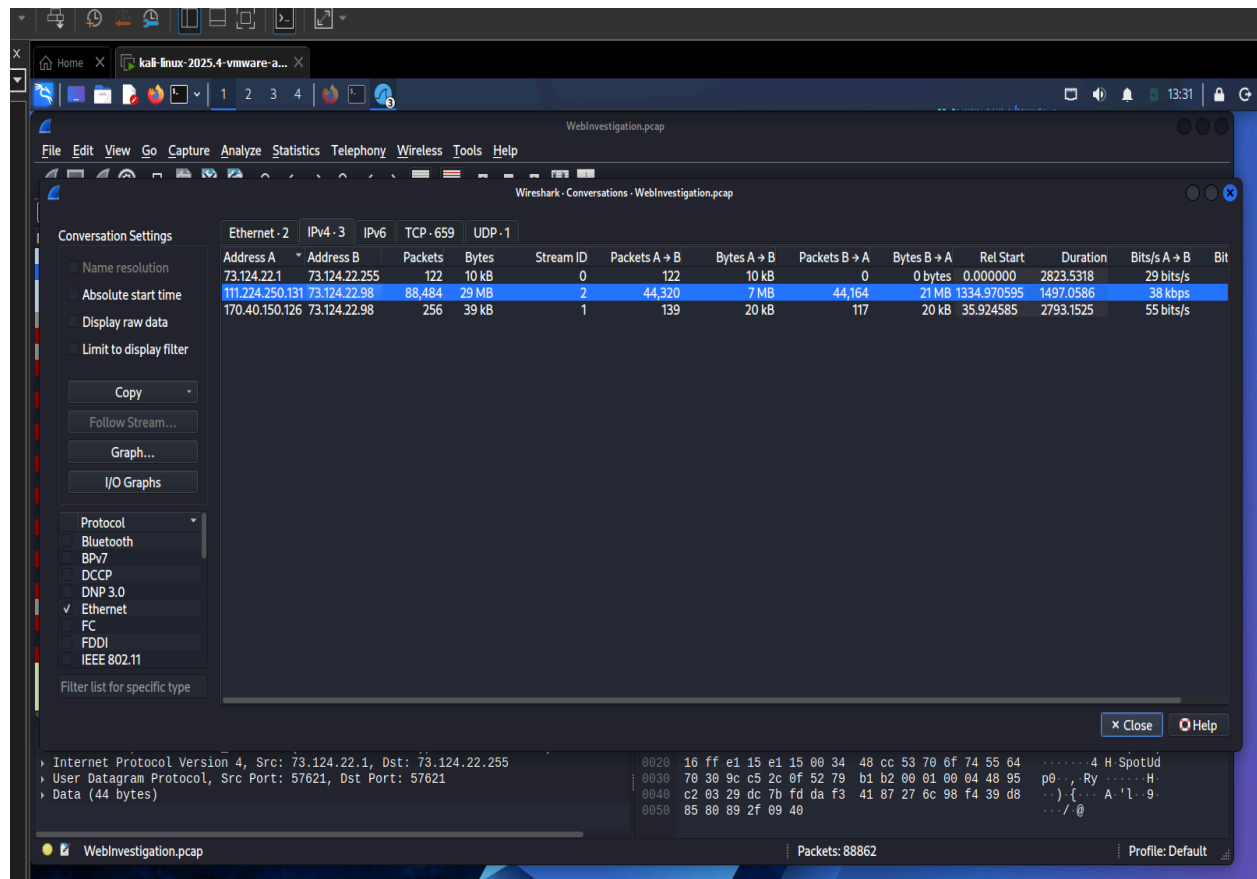
1. Using Wireshark statistics and conversation analysis features.

Identify:

- * External systems communicating excessively with BookWorld servers
- * Internal servers receiving abnormal traffic volumes

Exercise 2:

- * Identifying one suspicious external IP address.



Suspicious External IP Address here is:

111.224.250.131

Why this IP is considered suspicious based on traffic behavior?

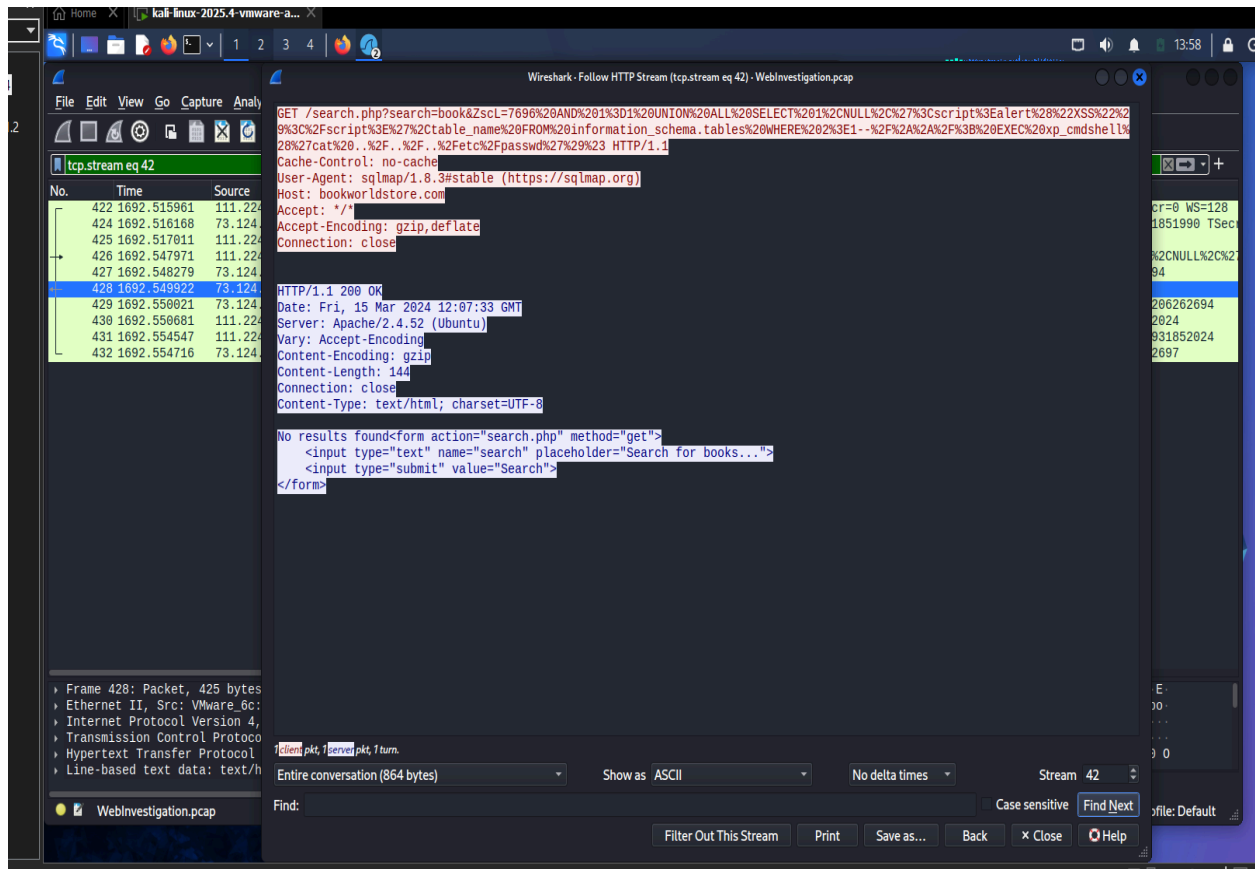
From the screenshot above you can see that this IP Address 111.224.250.131

1. Generated 88,484 packets, far more than any other host.
2. Transferred approximately 29 MB of data.
3. Maintained a long communication session about 1497 seconds.
4. Responsible for nearly all significant activity observed in the capture.

The unusually high traffic volume is consistent with automated requests and possible web-application enumeration or data extraction.

Exercise 3:

Identify suspicious web requests.



A malicious HTTP GET request was sent to:

/search.php

using the parameter:

search=

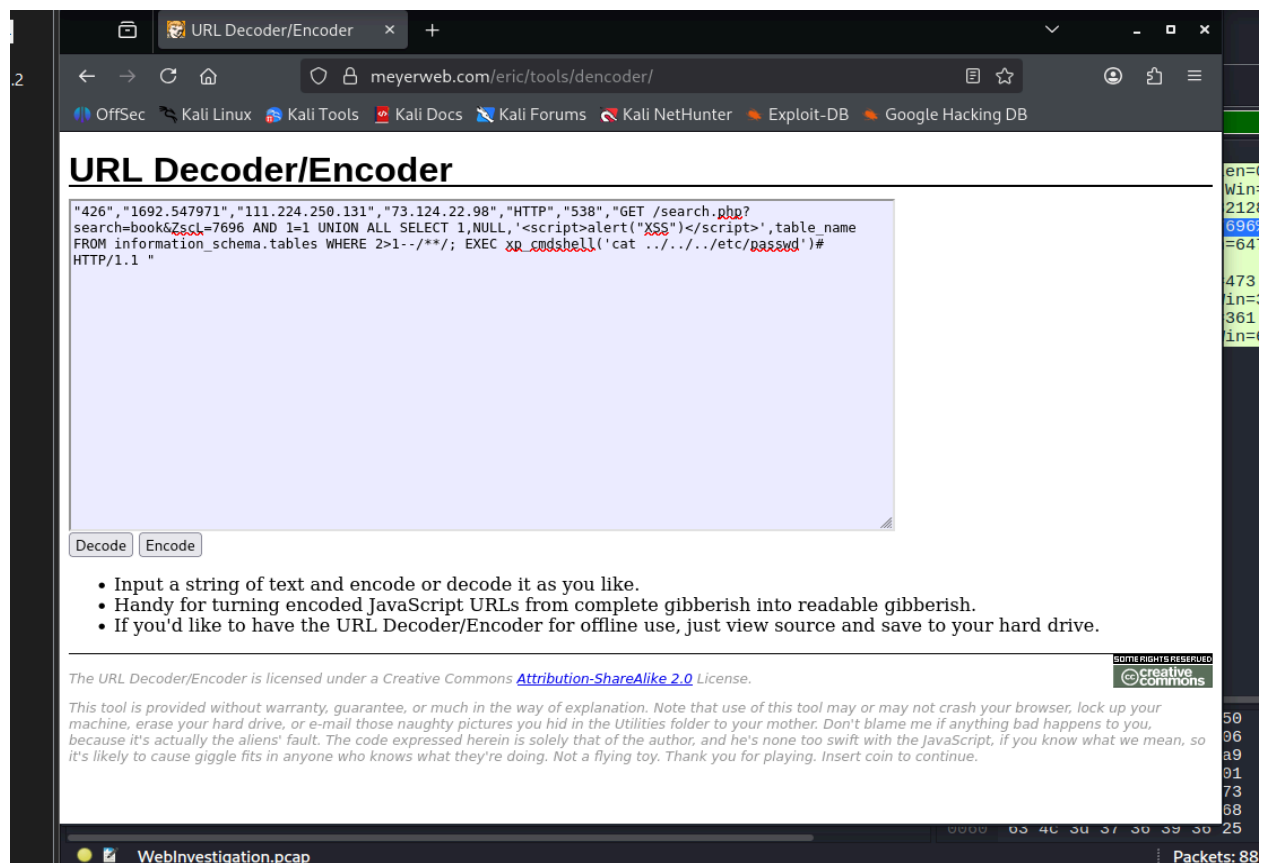
* Which endpoints or parameters appear abnormal?

Entry Point

1. /search.php
2. Parameter: search=

* Do you observe patterns consistent with brute-force, enumeration, or data extraction?

Yes:



URL Decoder/Encoder

search=book&Zsc=7696 AND 1=1 UNION ALL SELECT 1,NULL,'<script>alert("XSS")</script>',table_name FROM information_schema.tables WHERE 2>1--/**/; EXEC xp_cmdshell('cat ../../etc/passwd')# HTTP/1.1 "

Decode Encode

- Input a string of text and encode or decode it as you like.
- Handy for turning encoded JavaScript URLs from complete gibberish into readable gibberish.
- If you'd like to have the URL Decoder/Encoder for offline use, just view source and save to your hard drive.

The URL Decoder/Encoder is licensed under a Creative Commons [Attribution-ShareAlike 2.0](#) License.

This tool is provided without warranty, guarantee, or much in the way of explanation. Note that use of this tool may or may not crash your browser, lock up your machine, erase your hard drive, or e-mail those naughty pictures you hid in the Utilities folder to your mother. Don't blame me if anything bad happens to you, because it's actually the aliens' fault. The code expressed herein is solely that of the author, and he's none too swift with the JavaScript, if you know what we mean, so it's likely to cause giggle fits in anyone who knows what they're doing. Not a flying toy. Thank you for playing. Insert coin to continue.

WebInvestigation.pcap Packets: 88

1. The attacker tried to inject SQL injection which payload contains: UNION ALL SELECT used to extract data from a database.

2. The request references : information_schema.tables

indicated an attempt to enumerate database tables and discover the database structure.

3. The payload also includes: EXEC xp_cmdshell(...)

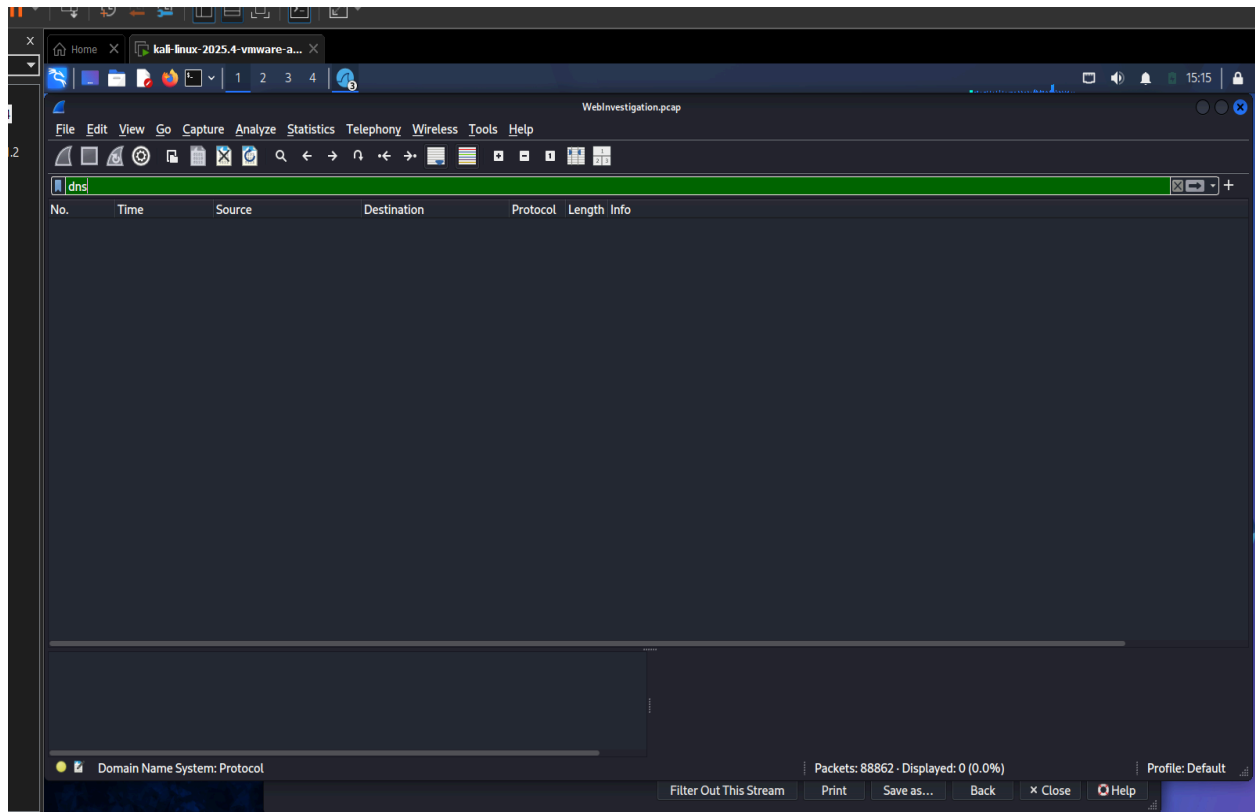
suggesting an attempt to execute operating system commands and access sensitive files.

There is no direct evidence of a password brute-force attack in the provided request, but there is clear evidence of automated probing and exploitation of the web application.

Exercise 4:

* Identify which database services appear to be targeted.

- * Identify unusual or suspicious domain queries.
- * Do any domains appear unrelated to BookWorld operations or algorithmically generated?



Dns filter shows 0 packets, indicating that no DNS queries were observed in the captured traffic

2. Data Exfiltration Indicators

Analyze outbound traffic patterns.

Exercise 6:

- * Is there evidence of large or abnormal data transfers?

Yes. The conversation between 111.224.250.131 and 73.124.22.98 transferred about 29 MB of data, which is significantly higher than other communications.

- * Which protocol or method appears to be used for exfiltration?

The data appears to have been transferred over HTTP, likely through SQL injection-based data extraction using the vulnerable web application.

Step 5: Attack Timeline Reconstruction

1. Identified:

- * Initial access
- * Exploitation phase
- * Data exfiltration phase

2. Use packet timestamps to reconstruct the incident timeline.

Exercise 7:

- * Reconstruct the attack sequence step by step.

From my findings so far:

1. The attacker connected to the BookWorld web server from 111.224.250.131.
2. SQLMap was used to send SQL injection payloads to search.php.
3. Database enumeration was performed using information_schema.tables.
4. Data was extracted through repeated HTTP requests.

- * At what point was customer data most at risk?

Customer data was most at risk during the database enumeration and data extraction phase after the SQL injection attack succeeded.

EXERCISE 8:

PROFESSIONAL FORENSIC INVESTIGATION REPORT

BOOKWORLD EXECUTIVE BRIEFING

1. Executive Summary

A forensic investigation was conducted on captured BookWorld network traffic to investigate unusual activity associated with the organization's web application. Analysis of the traffic identified an external host, 111.224.250.131, generating a significantly higher volume of HTTP traffic than other observed hosts.

Further investigation identified suspicious HTTP requests targeting the /search.php endpoint. The requests contained SQL injection indicators, including UNION ALL SELECT, references to information_schema.tables, and an SQLMap User-Agent.

The observed activity is consistent with automated web-application probing, database enumeration, and possible data extraction through SQL injection. Approximately 29 MB of data was transferred during the suspicious communication.

The available network evidence indicates that the BookWorld web application and its backend database were potentially exposed to unauthorized database enumeration and possible information extraction.

2. Incident Overview

The investigation was initiated following unusual network activity associated with BookWorld's web application.

Using Wireshark, the captured traffic was examined through packet statistics, conversation analysis, HTTP traffic inspection, and examination of individual requests.

The analysis identified a concentration of HTTP traffic involving the BookWorld web server. Further examination of the traffic revealed requests containing SQL injection payloads directed at the application's /search.php endpoint.

3. Identified Suspicious Host

The external IP address identified during the investigation was:

111.224.250.131

The host demonstrated unusual communication characteristics within the captured traffic:

- Approximately 88,484 packets were generated.
- Approximately 29 MB of data was transferred.
- The communication session lasted approximately 1,497 seconds.
- The host generated substantially more traffic than other observed hosts.

The unusually high traffic volume was consistent with automated requests and possible web-application enumeration or data extraction.

4. Targeted Application and Entry Point

The investigation identified the following application endpoint as the apparent entry point:

Endpoint: /search.php

Protocol: HTTP

Port: 80

The endpoint received repeated HTTP requests containing SQL injection-related parameters.

The traffic analysis indicated that the search functionality was being used to interact with the backend database in a manner inconsistent with normal application use.

5. SQL Injection Indicators

Several indicators of SQL injection activity were identified within the captured HTTP requests.

These included:

- UNION ALL SELECT
- information_schema.tables
- EXEC xp_cmdshell(...)
- SQLMap User-Agent

The reference to `information_schema.tables` is consistent with an attempt to enumerate database tables and determine the structure of the backend database.

The presence of `EXEC xp_cmdshell(...)` suggests an attempted operating-system command execution through the database environment.

The captured traffic therefore provides evidence of automated probing and attempted exploitation of the web application.

6. Database Enumeration and Possible Data Extraction

The investigation identified requests containing SQL injection payloads designed to interact with the backend database.

The use of:

`UNION ALL SELECT`

together with:

`information_schema.tables`

indicates database enumeration activity.

Approximately 29 MB of data was transferred during the suspicious communication between the identified hosts. The traffic appeared to have been transferred over HTTP and was potentially associated with SQL injection-based data extraction.

Based on the available network evidence, the activity should be described as possible data extraction rather than confirmed successful theft of customer information.

7. Attack Sequence

Based on the analysis of the captured traffic, the suspected attack sequence was reconstructed as follows:

1. An external host established communication with the BookWorld web server.
2. The `/search.php` endpoint was targeted through HTTP requests.
3. SQL injection payloads were submitted to the vulnerable web application.
4. Database enumeration was attempted using `information_schema.tables`.
5. Additional SQL injection activity included an `EXEC xp_cmdshell(...)` payload.
6. Repeated HTTP requests were generated during the activity.

7. Approximately 29 MB of data was transferred during the suspicious communication.
 8. The observed activity indicated possible database information extraction.
-

8. Affected Systems and Potential Impact

The investigation identified the following potentially affected components:

- BookWorld web server
- Backend database
- Web application search functionality
- Potential customer records accessible through the application

Potential security impacts include:

- Unauthorized database enumeration
- Potential exposure of customer information
- Possible extraction of database information
- Risk of continued exploitation if the vulnerability remains unresolved
- Potential compromise of the confidentiality and integrity of application data

These represent potential impacts based on the available evidence and do not establish that all of these impacts occurred.

9. Indicators of Compromise

Indicator	Observation
Suspicious External IP	111.224.250.131
Target Host	bookworldstore.com
Target Port	80
Application Endpoint	/search.php
Observed Tool	SQLMap 1.8.3
Attack Technique	SQL Injection
Database Enumeration	information_schema.tables
SQL Injection Indicator	UNION ALL SELECT

Additional Payload	EXEC xp_cmdshell(...)
Data Transfer	Approximately 29 MB

10. Network and DNS Observations

The Wireshark DNS filter displayed zero packets within the captured traffic. Therefore, no DNS queries matching the applied filter were observed in the available network capture.

The absence of DNS packets in the capture does not establish that DNS activity did not occur outside the captured traffic.

The investigation therefore focused primarily on the HTTP traffic and communication patterns that were available within the capture.

11. Recommendations

Based on the findings of the investigation, the following security measures are recommended:

1. Remediate the identified SQL injection vulnerability.
 2. Implement parameterized queries and appropriate input validation.
 3. Review database access permissions and apply the principle of least privilege.
 4. Review application and database logs for evidence of successful access or extraction.
 5. Examine the affected server for additional indicators of compromise.
 6. Strengthen web application logging and monitoring.
 7. Implement or improve intrusion detection controls for SQL injection and related web attacks.
 8. Conduct authorized vulnerability assessments and security testing.
 9. Apply appropriate security patches and configuration updates.
 10. Continue monitoring the affected endpoint for similar malicious activity.
-

12. Conclusion

The forensic investigation identified network activity consistent with an attempted SQL injection attack against the BookWorld web application.

The evidence included repeated HTTP requests, SQL injection payloads, database enumeration indicators, an SQLMap User-Agent, and significant data transfer. The /search.php endpoint was identified as the apparent entry point for the observed activity.

The available evidence indicates that the backend database may have been exposed to unauthorized enumeration and possible data extraction. Further examination of application, database, and server logs would be required to determine the full extent of any successful access or data exposure.